PENSE-BÊTE · DROIT ET STATUT

Cybersécurité des collectivités locales

01-65 Cybermalveillance - Obligations et responsabilités des collectivités locales en matière de cybersécurité — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La désignation d'un DPO indépendant est obligatoire pour toute collectivité locale ou établissement public.
2. Les téléservices doivent satisfaire au RGS et utiliser des solutions conformes aux spécifications eIDAS.
3. La responsabilité civile d'un élu peut être engagée personnellement si une faute est jugée détachable du service.

Obligations de protection des données personnelles

Notion	À retenir
Cadre et DPO	Guide de **2022** (avant NIS 2 et eIDAS 2). **Loi 78-17** et **RGPD**. **DPO** obligatoire, indépendant (agent, externe ou mutualisé). Responsable de traitement : **représentant légal** (maire, président d'EPCI).
Mesures de sécurité	Avant : **analyse d'impact** si risque élevé. Pendant : **minimisation** et mesures techniques (**chiffrement**, **sauvegardes testées**, mises à jour).
Violations et conservation	Violation à risque : **CNIL sous 72 h** ; personnes informées si risque élevé. Base active → archivage intermédiaire → définitif ; durée proportionnée (ex. **bulletins de paie : 5 ans**).

Obligations téléservices et hébergement de données de santé

Notion	À retenir
Mise en œuvre téléservices	**RGS** (**décret du 2 février 2010**) : analyse des risques, objectifs, mesures, **homologation** (**attestation formelle** publique), suivi ; produits qualifiés **ANSSI**. Paiement en ligne obligatoire dès **5 000 €** de recettes.
Identification et signature	Soumises aux spécifications **eIDAS**. Solutions compatibles avec les standards européens (ex: `France Connect`). Signature doit avoir un niveau de sécurité **équivalent ou supérieur**.
Hébergement données santé	Externalisation soumise à **certification préalable** par un organisme agréé. **Centres hospitaliers**, **GCS** ou **EPCI** doivent être certifiés s'ils hébergent pour autrui.

Responsabilité administrative de la collectivité

Notion	À retenir
Sanctions CNIL	Montant max : **20 millions d'euros** ou **4 % du chiffre d'affaires**. S'applique aux collectivités, établissements et **sociétés d'économie mixte**.
Faute de l'administration	Responsabilité engagée si un manquement aux **obligations** ou à la **réglementation des SI** cause un préjudice (ex: **téléservice** défaillant).
Dommage de travaux publics	Responsabilité pour **défaut d'entretien** d'un ouvrage ou accessoire (ex: piratage **réseau d'épuration** ou **signalisation lumineuse**).

Responsabilité civile des élus et des agents publics

Notion	À retenir
Faute détachable	Engage la responsabilité sur le **patrimoine personnel** si les faits révèlent des **préoccupations d'ordre privé**, sont **incompatibles avec les fonctions** ou revêtent une **particulière gravité**.
Cumul et recours	Une faute commise avec l'**autorité** et dans l'**exercice des fonctions** peut être à la fois **faute de service** et **faute personnelle**. La collectivité peut engager une **action récursoire** contre l'auteur.

Responsabilité pénale des élus et des agents

Notion	À retenir
Violation protection données	**Art. 226-17 Code pénal** : **5 ans** d'emprisonnement et **300 000 €** d'amende pour absence de **mesures de sécurité** ou de **registre des traitements**.
Fautes imprudence/négligence	**Art. 121-3 Code pénal** : poursuites si **violation manifeste** d'une règle de prudence/sécurité ou **faute caractérisée** (risque grave et immédiat) causant une **atteinte à l'intégrité physique**.

Pièges et confusions

- ⚠ Croire que le traitement de données personnelles nécessite obligatoirement un procédé automatisé.
- ⚠ Confier la fonction de DPO au **directeur général** ou au **responsable informatique** : risque de **conflit d'intérêts**.
- ⚠ Oublier qu'une violation de données personnelles doit être signalée à la CNIL dans un délai de 72 heures si elle présente un risque.
- ⚠ Penser que la responsabilité d'un élu ne peut pas être engagée sur son patrimoine propre.

Sigles et définitions

RGPD	règlement 2016/679 relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel
CNIL	organisme qui supervise les questions relatives à la protection des données personnelles et peut prononcer des sanctions administratives
DPO	délégué à la protection des données qui doit être désigné par toute collectivité locale ou établissement public pour exercer en toute indépendance
RGS	ensemble de règles de sécurité édicté par le décret du deux février 2010 qui s'applique aux téléservices
ANSSI	organisme qui qualifie les produits de sécurité et les prestataires de confiance
eIDAS	règlement européen sur l'identification électronique et les services de confiance pour les transactions électroniques au sein de l'Union européenne
donnée personnelle	information se rapportant à une personne physique identifiée ou identifiable, directement ou indirectement
faute détachable du service	faute civile qui permet d'engager la responsabilité personnelle d'un élu ou d'un agent sur son patrimoine propre

Auto-test

1. Quel est le délai de signalement d'une violation de données personnelles à la CNIL ?
2. Quel règlement s'applique aux téléservices concernant la sécurité ?
3. Quel est le montant maximum des sanctions administratives de la CNIL ?
4. Quelle est la peine encourue pour absence de mesures de sécurité selon l'Art. 226-17 du Code pénal ?
5. Qui est en pratique le responsable de traitement d'une collectivité ?

Réponses : **1.** 72 heures · **2.** Le RGS · **3.** 20 millions d'euros ou 4 % du CA · **4.** 5 ans d'emprisonnement et 300 000 € d'amende · **5.** Son représentant légal (maire, président d'EPCI).

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.